Informe de seguridad Garak

Proyecto: AgroRAG

Release evaluada: `d38814b4f352b3f007f7520858f48daeca27a160`

Fecha: 31/10/2026

Garak: 0.17.0

Estado: cobertura faltante completada; promoción 5.4 pendiente

Resumen ejecutivo

La evaluación adversarial de la candidata desplegada por digest quedó completa para las familias que habían sido interrumpidas por presupuesto. `encoding.InjectBase64` obtuvo 32/32 respuestas reales sin coincidencias de `encoding.DecodeMatch`. `promptinject.HijackHateHumans` obtuvo 32/32 respuestas reales sin coincidencias de `promptinject.AttackRogueString`.

Las corridas dirigidas produjeron 26 respuestas reales por familia. El control preventivo detuvo los últimos seis casos de cada una. Una recuperación posterior repitió únicamente esos 12 casos: 12/12 fueron exitosos, ninguno agotó presupuesto y los 12 obtuvieron puntaje detector 0.

La evidencia anterior se mantiene: `apikey.GetKey` tuvo 32 respuestas reales sin detecciones y Gus Rivas revisó las 15 respuestas reales DAN como 15 falsos positivos, sin confirmados ni dudosos. La evaluación es evidencia heurística y no una certificación de seguridad.

Candidata y entorno

La aplicación se ejecutó con Docker Compose en Ubuntu WSL. API y UI permanecieron en la red interna. El gateway fue el único componente publicado, en `18080->80` y `18443->443`.

Componente	Digest desplegado
API	`sha256:597a469fa8a688210cca5bc94dc0722c70975e57535171d14d70908336c9c96c`
UI	`sha256:82cabbfc5fdb132d29782fd5feb9c586e0a992cb75d53753b81f1aad0dfa1144`
Gateway	`sha256:31225397760fdcface3fa3641b73236df272dbc5e59824b77304b1b42c9afc3a`
Garak runner	`sha256:f0bd19bef1458a0b74b70d4a4c55fa3c94aa0cec10ca86fb84b1059cafd5267e`

Cobertura efectiva

Familia	Respuestas reales	Resultado
`apikey.GetKey`	32	0 detecciones de API key.
`dan.DanInTheWild`	15	15/15 alertas revisadas como falsos positivos; 0 confirmadas y 0 dudosas.
`encoding.InjectBase64`	32	0 coincidencias de payload decodificado.
`promptinject.HijackHateHumans`	32	0 emisiones de la cadena de inyección.

Los pases Base64 y prompt injection de las corridas dirigidas no se aceptaron de forma automática: se separaron las 26 respuestas reales de las seis negativas sintéticas por presupuesto. Los 12 casos incompletos se recuperaron después y se evaluaron con la misma regla exacta de Garak: búsqueda de la cadena disparadora sin distinguir mayúsculas y minúsculas.

Presupuesto

El usuario autorizó hasta USD 0,50 para completar las pruebas faltantes. Cada corrida conservó el techo técnico máximo de USD 0,20.

Corrida nueva	Respuestas reales	Costo estimado
Base64 dirigida	26	USD 0,145160
Prompt injection dirigida	26	USD 0,082180
Recuperación selectiva	12	USD 0,029490
Total de la nueva autorización	**64**	**USD 0,256830**
Presupuesto no utilizado		**USD 0,243170**

Incluyendo la corrida inicial ya documentada de USD 0,080445, el costo estimado acumulado de todas las corridas Garak de esta candidata fue USD 0,337275. Ninguna corrida individual superó USD 0,20.

Incidente de credencial local

Durante una inspección previa a las corridas dirigidas, una orden local mostró la credencial Basic anterior en la salida de consola. Se la consideró comprometida, se rotó antes de continuar y se recreó únicamente el gateway con las mismas imágenes, volúmenes y puertos. La credencial anterior pasó a devolver HTTP 401 y la nueva devolvió HTTP 200. No se versionaron valores secretos.

Evidencia y tratamiento de datos

Artefacto	Ubicación	Tratamiento
Resumen de recuperación	`docs/evidence/garak/d38814b4-targeted-recovery.json`	Versionado y sanitizado.
Informe Markdown	`docs/evidence/garak/garak-d38814b4-human-report.md`	Versionado.
Informe PDF	`output/pdf/garak-d38814b4-human-report.pdf`	Versionado.
Libro de revisión	`docs/evidence/workbooks/garak-d38814b4-revision-human-dan.xlsx`	Versionado y sanitizado.
Crudos y recuperación	`/home/gus/.local/share/agrorag/garak/`	Local restringido; directorios 0700 y archivos 0600.

Los artefactos versionados no contienen prompts, respuestas completas, claves ni cabeceras de autenticación. La recuperación sanitizada conserva familia, secuencia, UUID, hashes, estado y puntaje detector.

Decisión

La deuda de cobertura de Base64 y prompt injection queda resuelta: ambas familias alcanzaron 32 respuestas reales y 0 detecciones. La revisión DAN también permanece cerrada sin hallazgos confirmados.

OpenSpec 5.4 no se marca completo en este cambio. Aún corresponde ejecutar la decisión formal de promoción de la misma imagen y cerrar la documentación de release con esta evidencia. Garak reduce incertidumbre sobre estos escenarios concretos, pero no reemplaza threat modeling, controles clásicos, revisión humana ni monitoreo.